

Module 4: Web Application Security



Topic 1: Web Application Basics



What is URL?

Uniform Resource Locator (URL): It is a reference to a web resource that specifies its location on a computer network and a mechanism for retrieving it.

URL Components(RFC 3986)



What is URL?

Scheme:

- HTTP
- File

Example HTTP URLs:

- `http://<sub.domain.tld>:<port>/`
- `http://<user>:<pass>@<sub.domain.tld>/path1/path2`
- `http://<user>:<pass>@<sub.domain.tld>/path?q1=a&q2=b`
- `http://<user>:<pass>@<sub.domain.tld>/path?q1=a&q2=b#URL Fragment`

Example FILE URLs:

- `file:///etc/passwd`
- `file:///c:/WINDOWS/win.ini`

What is HTTP?

Request

```
GET / HTTP/1.1
Accept: application/vnd.ms-excel, application/msword, application/vnd.ms-powerpoint,
image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, */*
Accept-Language: he
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.0)
Host: www.site.com
Connection: Keep-Alive
```



Response

```
HTTP/1.1 200 OK
Server: Microsoft-IIS/5.0
Date: Fri , 29 Aug 1997 02:14:00 GMT
Set-Cookie: SessionId=raqngbihvwpypof45rujbce45; path=/
Content-Type: text/html;
Content-Length: 39

<html>
<H1> HELLO WORLD </H1>
</html>
```



HTTP Methods and Responses

HTTP Verb (Methods) indicate the desired action to be performed for a given resource.

- **GET** –Mainly used to request resources (Parameters in URL)
- **POST** –Form submissions, data in message body
- **OPTIONS** –List of methods supported for URL
- **HEAD** –Response for GET but no message body
- **TRACE** –Echo client request back for diagnoses
- **PUT** –Store in URI
- **DELETE** –Delete resource

HTTP Methods and Responses

- **1XX:** informational, The client SHOULD continue with its request
- **2XX:** Successful, The client's request was successfully received, understood, and accepted.
- **3XX:** Redirection, Further action needs to be taken by the user agent in order to fulfill the request
- **4XX:** Client Error.
- **5XX:** Server Error, The server is aware that it has erred or is incapable of performing the request

HTTP Methods and Responses

```
HTTP/1.1 200 OK
Date: Sun, 05 Nov 2006 10:12:57 GMT
Server: Apache/2.2.3 (Unix) mod_ssl/2.2.3 OpenSSL/0.9.7g
Content-Length: 26
Connection: close
Content-Type: text/html; charset=iso-8859-1

<html> Hello World </html>
```

```
HTTP/1.1 302 Redirect
Content-Length: 165
Content-Type: text/html
Location: http://demo.testfire.net/bank/default.aspx
Server: Microsoft-IIS/6.0
X-Powered-By: ASP.NET
Date: Sun, 05 Nov 2006 10:07:53 GMT
Connection: close

<head><title>Document Moved</title></head>
<body><h1>Object Moved</h1>This document may be found <a href="http://demo.testf
ire.net/bank/default.aspx">here</a></body>
```


HTTP Methods and Responses

```
HTTP/1.1 404 Not Found
Date: Sun, 05 Nov 2006 10:15:57 GMT
Server: Apache/2.2.3 (Unix) mod_ssl/2.2.3 OpenSSL/0.9.7g
Content-Length: 37
Connection: close
Content-Type: text/html; charset=iso-8859-1

<html> The Page Was Not Found </html>
```

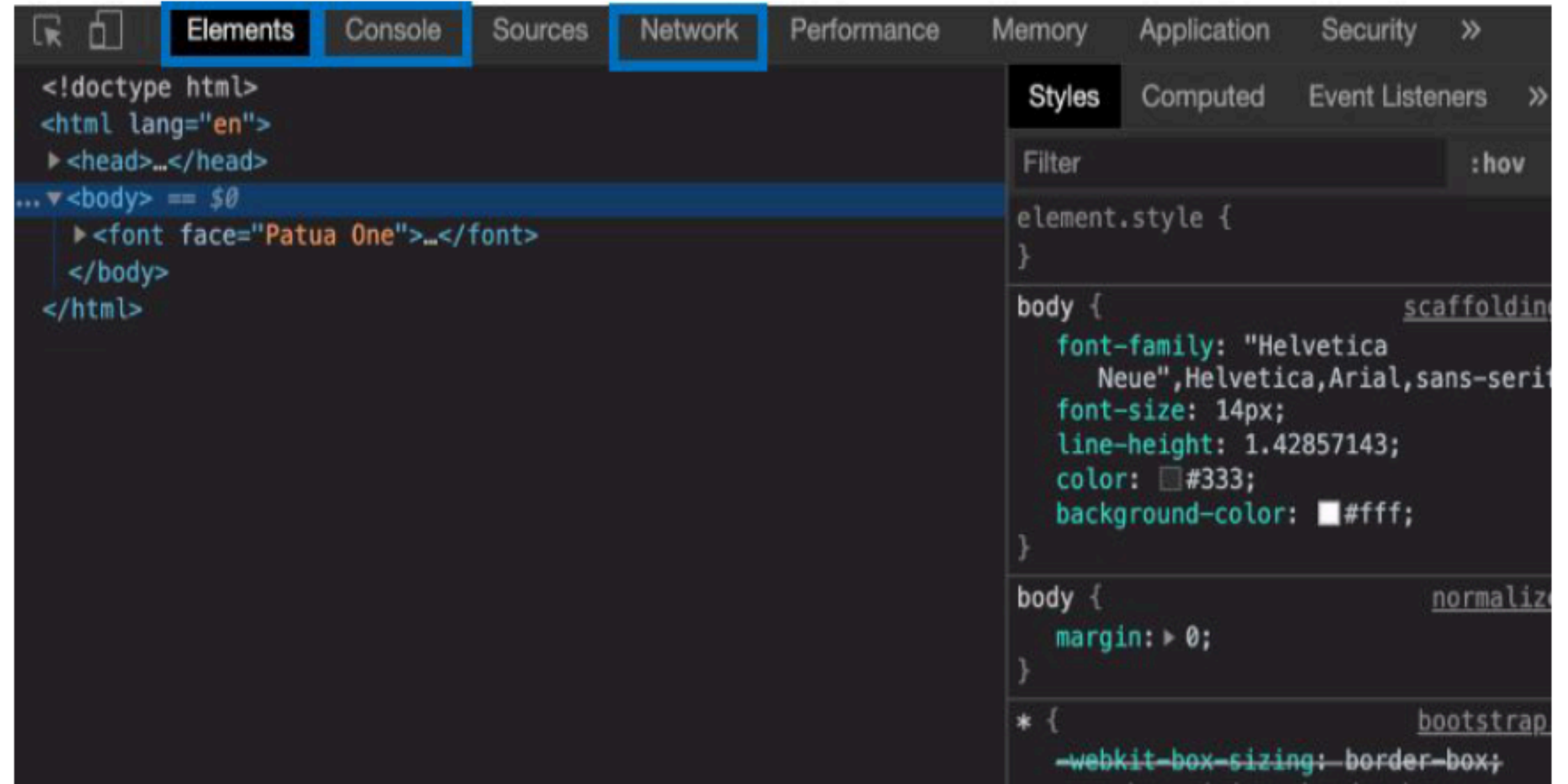
```
HTTP/1.1 500 Internal Server Error
Date: Sun, 05 Nov 2006 10:18:57 GMT
Server: Apache/2.2.3 (Unix) mod_ssl/2.2.3 OpenSSL/0.9.7g
Content-Length: 37
Connection: close
Content-Type: text/html; charset=iso-8859-1

<html> CGI Error </html>
```

Web Browser is your Weapon

Your Browser can do analysis and trace

- View Source
- Inspect



Web Browser is your Weapon

The screenshot shows a web browser's cookie management interface. On the left, a sidebar menu includes options like 'Manage all Cookies', 'Search Cookies for: www.w3schools.com', 'Delete current Site Cookies (13)', 'Delete current Context Cookies (99+)', 'Delete current Domains (2)', and 'Options'. The main area is divided into three sections: 'Cookies', 'Details', and 'Path'. The 'Cookies' section lists various cookies, including '_gat', '__gads', '__gpi', 'lotame_domain_check', '_cc_id', 'panoramald_expiry', 'panoramald', 'cto_bundle', '_ga', and '_gid'. The 'Details' section provides information for the selected '_gat' cookie, such as its domain (.w3schools.com), name, value (1), path (/), context (Default), and expiration date (17-06-2022 15:07:06).

Manage all Cookies

Search Cookies for: www.w3schools.com

Delete current Site Cookies (13)

Delete current Context Cookies (99+)

Delete current Domains (2)

Options

Domains (2)

- .w3schools.com (10)
- www.w3schools.com (3)

Cookies

- _gat:1**
- __gads:**ID=72dd37f7faa4858a-22e78f9405d400b1:T=1655492768:S=ALNI_MbSVIdkv11k3L1VTneQJtkz7Lq9iA
- __gpi:**UID=000008fcced9e8d7:T=1655492768:RT=1655492768:S=ALNI_MbqIG...m2_sDhA0DvHE740Q
- lotame_domain_check:**w3schools.com
- _cc_id:**d49e4d9d8ee2ea38903494c3da2b5ad7
- panoramald_expiry:**1656097585282
- panoramald:**2be2ef42e1805b8bfaa002ab0b1e4945a7024e0004060dd93e4971e...
- cto_bundle:**ixmbkF8lMkl3NGhnQ3dXNGZxSkZjVnZMQ09EdWpnVFpld2RnN2Uy...
- _ga:**GA1.2.1646544603.1655492764
- _gid:**GA1.2.304261076.1655492764

Details

Domain: .w3schools.com

First-Party:

Name: _gat

Value: 1

Path: /

Context: Default

httpOnly: ☐ sameSite: ☐ No restriction

isSecure: ☐

isSession: ☐

Expire: 17-06-2022 15:07:06

Web Browser is your Weapon

